

Botium Toys

Date: 5/21/2026

Prepared by Skyler Farr

Course: Google Cybersecurity

Summary

Botium Toys is experiencing rapid growth in its online market, but its current security posture has not kept pace with this expansion. The internal audit identified several gaps across access control, network security, data protection, logging and monitoring, and regulatory compliance. Many critical controls are either missing or undocumented, which increases the company's exposure to operational disruptions, data breaches, and regulatory penalties.

Because Botium Toys processes online payments and serves customers in the European Union, the lack of PCI DSS and GDPR compliance represents a significant financial and legal risk. Additionally, the absence of formal access controls, encryption standards, and centralized logging leaves the organization vulnerable to unauthorized access and undetected security incidents.

Overall, Botium Toys would benefit from implementing foundational security controls, establishing formal policies and procedures, and prioritizing compliance with PCI DSS and GDPR. Addressing these gaps will strengthen the company's security posture, reduce risk, and support safe and sustainable business growth.

Scope of Audit

The scope of this internal IT audit includes all systems, processes, and assets currently managed by the Botium Toys IT department. This covers the company's single physical location, including the main office, storefront, and warehouse operations. The audit also includes the organization's online infrastructure that supports domestic and international customers, with a focus on systems involved in processing online payments and storing customer information.

The scope further includes evaluating Botium Toys' alignment with the NIST Cybersecurity Framework (CSF), reviewing existing security controls, and assessing risks related to data protection, access control, network security, and incident response. Because the company conducts business in the European Union and processes online payments, the audit also examines compliance requirements related to PCI DSS and GDPR.

Methodology

The internal audit was conducted using the National Institute of Standards and Technology Cybersecurity Framework (NIST CSF) as the guiding standard. The audit process included reviewing the IT manager's scope, goals, asset inventory, and risk assessment to understand Botium Toys' current security posture. Each control category was evaluated by comparing the organization's existing practices against industry best practices and the requirements outlined in the NIST CSF.

The methodology involved analyzing documented risks, identifying gaps in security controls, and assessing whether current processes support compliance with PCI DSS and GDPR. A controls and compliance checklist was completed to determine whether required safeguards are implemented, partially implemented, or missing. Findings were based solely on the information provided in the risk assessment and supporting materials, with assumptions minimized to maintain objectivity.

This approach ensures a consistent, structured evaluation of Botium Toys' security controls and provides a clear foundation for identifying vulnerabilities, prioritizing remediation efforts, and improving overall compliance and risk management.

Risk Rating Levels

High – Immediate action required

Medium – Needs remediation soon

Low – Monitor or fix when possible

Finding ID	Description	Risk Level	Evidence	Recommendation
F-01	Lack of multi-factor authentication (MFA) for administrative and critical systems	High	Risk assessment notes missing access controls and no mention of MFA	Implement MFA for all admin accounts and customer-facing systems to reduce unauthorized access risk
F-02	Customer and payment data is not encrypted at rest or in transit	High	No encryption controls listed in asset inventory or risk assessment	Implement industry-standard encryption (AES-256, TLS 1.2+) for all sensitive data
F-03	No centralized logging or monitoring solution in place	Medium	Risk assessment highlights lack of monitoring and incident detection capabilities	Deploy centralized logging (e.g., SIEM) to detect suspicious activity and support incident response
F-04	Organization is not PCI DSS compliant despite processing online payments	High	IT manager expressed concern about compliance with online payment regulations	Begin PCI DSS compliance program, including network segmentation, encryption, and access controls

Recommendations

- **Implement multi-factor authentication (MFA)** for all administrative accounts and customer-facing systems to reduce the risk of unauthorized access.
- **Encrypt all sensitive customer and payment data** at rest and in transit using industry-standard encryption protocols.
- **Deploy centralized logging and monitoring**, such as a SIEM solution, to improve visibility into security events and support incident response.
- **Begin a PCI DSS compliance program** to ensure secure handling of payment card data and reduce the risk of regulatory fines.
- **Implement GDPR compliance measures**, including data minimization, consent management, and appointing a Data Protection Officer (DPO) to oversee privacy requirements.
- **Develop formal security policies and procedures**, including access control, password standards, data protection, and incident response.
- **Conduct regular risk assessments and internal audits** to ensure continuous improvement of the security posture as the company grows.

Conclusion

The internal audit revealed that Botium Toys is facing significant security and compliance risks as the company expands its online presence and processes customer data globally. Several foundational controls—such as MFA, encryption, centralized logging, and formal security policies—are currently missing or insufficiently implemented. Additionally, the organization is not yet compliant with PCI DSS or GDPR, which presents substantial legal and financial exposure.

By prioritizing the implementation of essential security controls and establishing a structured compliance program, Botium Toys can significantly reduce its risk profile and strengthen its overall security posture. Addressing these gaps will help the company protect customer data, maintain trust, and support safe and sustainable business growth as operations continue to scale.